Palo Alto Networks — Proyecto No. 1

UNIVERSIDAD AUTÓNOMA DE CHIRIQUÍ

FACULTAD DE ECONOMÍA

LICENCIATURA EN GESTIÓN DE TECNOLOGÍA DE INFORMACIÓN

Asignatura: Seguridad Informática · Código de asignatura: 28169 · Código: PROG 431

PROYECTO No. 1

Investigación sobre las Consecuencias de las Vulnerabilidades Informáticas

PALO ALTO NETWORKS: PLATAFORMA DE CIBERSEGURIDAD FRENTE A LAS VULNERABILIDADES

Estudiante: **Dereck Martínez**

Profesor: **Prof. Andrés Miranda**

Fecha: **01 de octubre de 2026**

David, Chiriquí — República de Panamá

Introducción

Una vulnerabilidad informática es una debilidad en un sistema, una aplicación o un proceso que un atacante puede aprovechar para robar datos, interrumpir servicios o tomar el control de un equipo. Ninguna organización puede eliminarlas todas, porque el software nuevo trae fallos nuevos cada día; lo que sí puede hacer es detectarlas antes que el atacante y bloquear su explotación.

En esta investigación estudio a Palo Alto Networks, la empresa estadounidense que inventó el firewall de nueva generación (NGFW) y que hoy ofrece una plataforma completa para proteger la red, la nube, el centro de operaciones de seguridad (SOC), las identidades y la inteligencia artificial. Analizo sus conceptos, características, las amenazas que enfrenta, las consecuencias de no proteger una vulnerabilidad, cómo previene los ataques, sus ventajas y desventajas, y un caso real: la vulnerabilidad CVE-2024-3400 que afectó a sus propios firewalls.

Ese caso es importante para el tema del proyecto, porque demuestra que incluso las herramientas de seguridad tienen vulnerabilidades, y que las consecuencias de no corregirlas a tiempo pueden ser graves.

1. Conceptos

Palo Alto Networks es una empresa de ciberseguridad fundada en 2005 por Nir Zuk, con sede en Santa Clara, California. Cotiza en Nasdaq bajo el símbolo PANW, la dirige Nikesh Arora desde 2018 y reportó ingresos de US$11.48 mil millones en el año fiscal 2026, un 25 % más que en 2025.

1.1 Vulnerabilidad, amenaza y riesgo

- **Vulnerabilidad:** el fallo o debilidad (un error de código, una configuración insegura, una contraseña débil).
- **Amenaza:** quien o lo que puede aprovechar ese fallo (un grupo criminal, un malware, un empleado descuidado).
- **Exploit:** el código o técnica concreta que aprovecha la vulnerabilidad.
- **Riesgo:** la probabilidad de que la amenaza explote la vulnerabilidad, multiplicada por el daño que causaría.
- **CVE:** el identificador público con que se cataloga cada vulnerabilidad conocida (por ejemplo, CVE-2024-3400).

1.2 Conceptos propios de Palo Alto Networks

Concepto	Qué significa
NGFW (firewall de nueva generación)	Firewall que identifica la aplicación, el usuario y el contenido del tráfico, no solo puertos y protocolos.
SP3 (Single-Pass Parallel Processing)	Arquitectura en la que cada paquete se inspecciona una sola vez y el hardware procesa en paralelo.

Concepto	Qué significa
App-ID	Identifica qué aplicación genera el tráfico, aunque cambie de puerto o vaya cifrada.
User-ID	Asocia el tráfico con el usuario real del directorio de la empresa.
Content-ID	Revisa el contenido en busca de exploits, malware, URLs peligrosas y datos sensibles.
SASE	Seguridad entregada desde la nube para usuarios remotos y sucursales.
CNAPP	Protección de aplicaciones nativas de la nube durante todo su ciclo de vida.
XDR	Detección y respuesta extendida: correlaciona eventos de endpoints, red y nube.
SOC	Centro de operaciones de seguridad que vigila y responde a incidentes.
Platformization	Estrategia de consolidar herramientas de muchos proveedores en una sola plataforma.

2. Características

La característica central de Palo Alto Networks es que no vende productos sueltos, sino una plataforma de cuatro pilares que comparten datos y una misma inteligencia artificial (Precision AI).

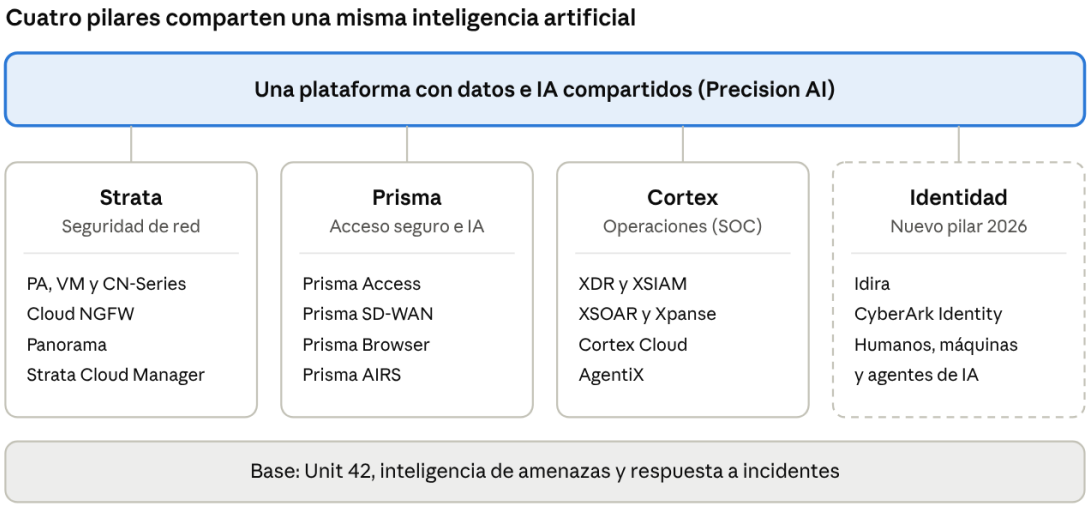


Figura 2 · Los cuatro pilares de la plataforma (elaboración propia)

2.1 Los pilares de la plataforma

Pilar	Área	Productos principales
Strata	Seguridad de red	PA-Series, VM-Series, CN-Series, Cloud NGFW, Panorama, Strata Cloud Manager
Prisma	Nube y acceso seguro	Prisma Access, Prisma SD-WAN, Prisma Browser, Prisma AIRS
Cortex	Operaciones de seguridad (SOC)	Cortex XDR, XSIAM, XSOAR, Xpanse, Cortex Cloud, AgentiX
Identidad (desde 2026)	Identidades humanas, de máquina y de IA	Idira / CyberArk Identity Security

Unit 42, su equipo de inteligencia de amenazas y respuesta a incidentes, atraviesa los cuatro pilares.

2.2 Rasgos técnicos que la distinguen

- **Inspección en una sola pasada (SP3):** red, políticas, App-ID, User-ID y Content-ID trabajan sobre el mismo paquete en un solo recorrido.
- **Plano de control separado del plano de datos:** la gestión y los registros no compiten por recursos con la inspección del tráfico.
- **Prevención en línea:** bloquea en el momento, no después de que el ataque ocurrió.
- **Despliegue en cualquier forma:** hardware físico, máquina virtual, contenedores de Kubernetes o servicio en la nube.
- **Multinube:** protege cargas en AWS, Azure, Google Cloud, Oracle y Alibaba.
- **Gestión centralizada:** Panorama y Strata Cloud Manager administran cientos de firewalls desde una consola.
- **Automatización con IA:** XSIAM y los agentes AgentiX analizan alertas y responden sin intervención manual.

2.3 Línea de tiempo

Año	Hito
2026	Compra CyberArk (~US$25 mil millones) y lanza Idira
2025	Prisma Cloud evoluciona a Cortex Cloud; Nir Zuk se retira
2021	Traslada su cotización a Nasdaq
2019	Nacen las marcas Prisma y Cortex
2018	Nikesh Arora asume como CEO

Año	Hito
2012	Sale a bolsa en NYSE y recauda US$260 millones
2007	Lanza su primer firewall de nueva generación
2005	Nir Zuk funda la empresa

3. Amenazas

Palo Alto Networks enfrenta dos tipos de amenazas: las que intenta detener en las redes de sus clientes y las que apuntan contra sus propios productos.

3.1 Amenazas que la plataforma bloquea

Amenaza	Cómo entra	Qué la detiene
Malware y ransomware	Archivos adjuntos, descargas, USB	WildFire, Threat Prevention, Cortex XDR
Explotación de vulnerabilidades	Servicios expuestos sin parche	Threat Prevention (IPS), Cortex XDR
Phishing	Correos y sitios falsos	Advanced URL Filtering, Prisma Browser
Comando y control (C2) por DNS	Malware que se comunica con su servidor	DNS Security
Fuga de datos	Empleados o malware que extraen información	DLP, Content-ID
Robo de credenciales	Contraseñas filtradas o reutilizadas	Idira/CyberArk, User-ID
Configuraciones inseguras en la nube	Buckets públicos, permisos excesivos	Cortex Cloud (CSPM, CIEM)
Dispositivos IoT vulnerables	Cámaras, impresoras, sensores sin parche	IoT Security
Ataques a modelos de IA	Inyección de instrucciones, fuga de datos del modelo	Prisma AIRS
Activos olvidados expuestos en internet	Servidores que la empresa no sabe que tiene	Cortex Xpanse

3.2 Amenazas contra sus propios productos

Los firewalls y las VPN son blancos atractivos: están siempre expuestos a internet y, si caen, dan acceso a toda la red interna. Por eso grupos de espionaje patrocinados por estados buscan fallos en sus sistemas operativos.

- **CVE-2024-3400 (abril 2024):** inyección de comandos en GlobalProtect de PAN-OS, puntuación CVSS 10.0. Se explotó como día cero antes de existir parche. Es el caso que desarrollo en la sección 7.
- **CVE-2024-0012 y CVE-2024-9474 (noviembre 2024):** omisión de autenticación y escalada de privilegios en la interfaz web de gestión de PAN-OS, encadenadas para tomar control del firewall.
- **Interfaces de gestión expuestas:** miles de firewalls tenían su panel de administración accesible desde internet, contra la recomendación del fabricante, lo que multiplicó el impacto de los fallos anteriores.

4. Consecuencias

Cuando una vulnerabilidad se explota, el daño casi nunca se queda en el equipo afectado: se extiende a los datos, al dinero, a la reputación y a las obligaciones legales de la organización. Si la vulnerabilidad está en el propio firewall, la consecuencia es más grave, porque el atacante entra por la puerta que debía protegerla.

Tipo	Consecuencia	Ejemplo
Técnica	Control total del equipo comprometido	Ejecución de comandos como root en el firewall
Técnica	Movimiento lateral hacia la red interna	Robo de la base de datos de Active Directory
Información	Robo o secuestro de datos	Credenciales, datos de clientes, propiedad intelectual
Operativa	Interrupción de servicios	Red caída mientras se reinstala el equipo
Económica	Costos de respuesta, rescate y recuperación	Contratar forenses, reponer equipos, pagar horas extra
Legal	Multas y demandas	Incumplir la Ley 81 de 2019 de protección de datos personales en Panamá
Reputacional	Pérdida de confianza de clientes y socios	Clientes que cambian de proveedor tras la filtración
Para el fabricante	Desgaste de imagen y caída en bolsa	Avisos públicos de CISA y presión de clientes

Una sola vulnerabilidad sin parche puede convertirse en un incidente que dure semanas: primero el acceso inicial, luego la persistencia, después el robo de datos y, al final, la limpieza y la reconstrucción de la confianza.

5. Prevención

Palo Alto Networks previene en tiempo real: inspecciona cada paquete una sola vez y decide si lo deja pasar antes de que llegue a su destino.

5.1 Cómo previene: el recorrido de un paquete

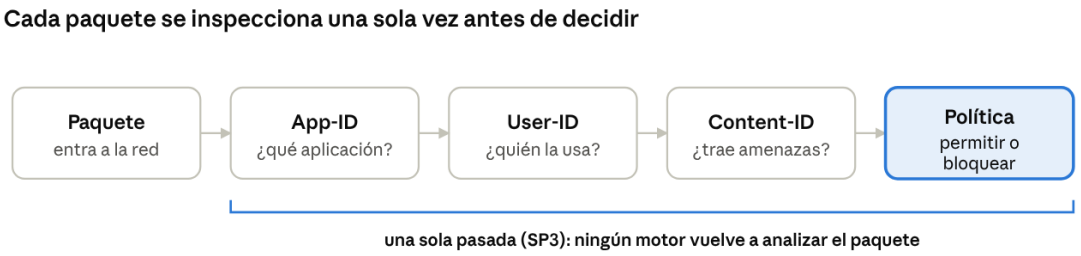


Figura 1 · Recorrido de un paquete en la arquitectura SP3 (elaboración propia)

En un firewall UTM tradicional (multi-pass), cada motor —antivirus, IPS, filtro de URL— vuelve a analizar el tráfico, lo que añade latencia y hace caer el rendimiento al activar funciones. En SP3 hay un solo análisis con un motor de firmas uniforme, así que la prevención va en línea sin frenar la red.

5.2 Capas de defensa de la plataforma

1. **Superficie de ataque:** Cortex Xpanse descubre lo que la empresa expone en internet.
2. **Perímetro y red:** NGFW con Threat Prevention, WildFire, URL y DNS Security.
3. **Acceso remoto:** Prisma Access aplica Zero Trust a cada usuario fuera de la oficina.
4. **Endpoint:** Cortex XDR bloquea exploits y malware en los equipos.
5. **Nube:** Cortex Cloud revisa código, configuraciones y cargas de trabajo.
6. **Identidad:** Idira/CyberArk protege cuentas privilegiadas y de máquina.
7. **Respuesta:** XSIAM y XSOAR automatizan la contención con playbooks.

5.3 Buenas prácticas para quien administra la plataforma

- Aplicar los parches de PAN-OS y los hotfixes apenas se publiquen; suscribirse a security.paloaltonetworks.com.
- Nunca exponer la interfaz de gestión a internet: limitarla a una red de administración o a IPs de confianza.
- Mantener actualizadas las firmas de Threat Prevention y activar los Threat IDs que el fabricante publica para cada vulnerabilidad.
- Activar el descifrado SSL/TLS donde la ley lo permita; sin él, Content-ID no ve el contenido cifrado.

- Aplicar el principio de mínimo privilegio en políticas y cuentas de administrador, con autenticación multifactor.
- Revisar los registros y la telemetría (Panorama, Strata Cloud Manager) y configurar alertas.
- Respaldar la configuración del firewall y tener un plan de respuesta a incidentes probado.

6. Ventajas y desventajas

Su mayor ventaja es la prevención en línea con una plataforma integrada; su mayor desventaja es el costo, que la aleja de las pequeñas empresas.

6.1 Ventajas

- **Prevención sin perder rendimiento:** SP3 inspecciona una vez, por lo que activar más funciones no frena la red como en un UTM tradicional.
- **Visibilidad real:** App-ID y User-ID muestran qué aplicación y qué persona generan cada conexión, no solo una IP y un puerto.
- **Plataforma integrada:** red, nube, SOC e identidad comparten datos e IA, lo que reduce herramientas y consolas.
- **Inteligencia de amenazas propia:** Unit 42 y WildFire convierten un malware visto en un cliente en protección para todos en minutos.
- **Automatización:** XSIAM y XSOAR reducen el tiempo de respuesta a incidentes.
- **Flexibilidad de despliegue:** físico, virtual, contenedores y nube, con gestión central.
- **Liderazgo reconocido:** es referente del mercado de firewalls de red desde hace más de una década.

6.2 Desventajas

- **Precio alto:** no publica precios de lista; se cotiza vía partner y las suscripciones anuales se suman al hardware.
- **Dependencia de suscripciones:** sin Threat Prevention, WildFire o URL Filtering, el firewall pierde gran parte de su valor.
- **Curva de aprendizaje:** PAN-OS y Cortex requieren formación y personal certificado.
- **Dependencia del fabricante (vendor lock-in):** cuanto más se consolida en la plataforma, más costoso es cambiar.
- **Sus productos también tienen vulnerabilidades:** CVE-2024-3400 y CVE-2024-0012 lo demostraron.
- **Descifrado necesario:** para inspeccionar tráfico cifrado hay que habilitar el descifrado, que consume recursos y plantea temas de privacidad.

6.3 Planes y precios referenciales

Plan	Qué ofrece	Precio referencial
Strata Cloud Manager Essentials	Gestión centralizada de NGFW y SASE, dashboards	Gratis
Strata Cloud Manager Pro	Essentials + AIOps predictivo y 1	Cotización

Plan	Qué ofrece	Precio referencial
	año de logs	
PA-Series (firewall físico)	NGFW + suscripciones	~€890 (PA-410) a ~€1 M (PA-7080)
Prisma Cloud Business	CSPM: postura y cumplimiento	~US$9,000 / 100 créditos / año
Prisma Cloud Enterprise	CNAPP completo	~US$18,000 / 100 créditos / año
Cortex XDR Prevent	Antimalware y bloqueo de exploits	~US$48–72 / endpoint / año
Cortex XDR Pro	+ EDR y analítica de comportamiento	~US$81–120 / endpoint / año
Prisma Access (Business Plus)	SASE: acceso remoto y web segura	~US$220 / usuario / año

Cifras de revendedores y marketplaces (2026); varían por volumen, región y negociación. Lo gratuito incluye Strata Cloud Manager Essentials, pruebas temporales, la herramienta open source Checkov y los cursos de Beacon.

7. Ejemplo de un caso: CVE-2024-3400 (Operación MidnightEclipse)

En abril de 2024, un grupo de espionaje explotó una vulnerabilidad de severidad máxima (CVSS 10.0) en los propios firewalls de Palo Alto Networks antes de que existiera un parche. Es un caso de día cero: el fabricante supo del fallo porque ya lo estaban usando contra sus clientes.

7.1 La vulnerabilidad

- **Producto:** función GlobalProtect Gateway de PAN-OS, el sistema operativo de los firewalls (The Register).
- **Tipo:** inyección de comandos (CWE-77) que permite a un atacante sin autenticación ejecutar comandos del sistema operativo con privilegios de root (Cybersecurity News).
- **Versiones afectadas:** PAN-OS 10.2, 11.0 y 11.1, solo con GlobalProtect y la telemetría del dispositivo activados.
- **No afectados:** Cloud NGFW, Panorama y Prisma Access (Arctic Wolf).

7.2 Cronología

Fecha	Qué ocurrió
26 mar 2024	Primeros intentos de explotación detectados después (H-ISAC / AHA)
10–11 abr 2024	Volexity detecta la explotación exitosa y movimiento lateral en un cliente que monitoreaba

Fecha	Qué ocurrió
12 abr 2024	Palo Alto Networks publica el aviso de seguridad y mitigaciones temporales
14 abr 2024	Se publican los primeros hotfixes (10.2.9-h1, 11.0.4-h1, 11.1.2-h3)

7.3 Cómo atacaron



Figura 3 · Cadena de ataque de CVE-2024-3400 (elaboración propia)

1. El grupo, que Volexity llamó UTA0218, envió peticiones manipuladas al portal de GlobalProtect expuesto a internet.
2. La inyección de comandos le dio ejecución remota en el firewall sin necesitar contraseña.
3. Creó un *reverse shell* y descargó herramientas adicionales al equipo.
4. Configuró una tarea programada (cron) que descargaba y ejecutaba código desde un servidor del atacante, para mantener acceso.
5. Instaló UPSTYLE, una puerta trasera escrita en Python que recibía órdenes ocultas en peticiones de red (PolySwarm).
6. Desde el firewall se movió lateralmente hacia la red interna de la víctima.

7.4 Consecuencias

- Organizaciones de varios sectores perdieron el control de su equipo perimetral, el que debía protegerlas.
- Por la sofisticación del ataque, Volexity lo atribuyó a un actor probablemente respaldado por un estado, aunque sin señalar a ningún país.
- Tras hacerse público, otros atacantes corrieron a explotar el fallo en equipos sin parchear.
- Los clientes afectados tuvieron que investigar, reconstruir los equipos y rotar credenciales.

7.5 Cómo se resolvió y qué enseña

Palo Alto publicó hotfixes, una firma de Threat Prevention para bloquear la explotación y la recomendación temporal de desactivar la telemetría. Unit 42 documentó la campaña como Operación MidnightEclipse.

La lección para el proyecto es directa: un producto de seguridad también es software con vulnerabilidades. La defensa depende de parchear rápido, no exponer servicios innecesarios y vigilar los propios equipos de seguridad. No era la primera vez: en 2019 otra falla de GlobalProtect (CVE-2019-1579) ya había sido explotada.

8. Vídeo instruccional

El vídeo muestra, en unos 5 minutos, cómo un firewall de Palo Alto Networks bloquea un intento de explotación y qué debe hacer el administrador para no repetir el caso CVE-2024-3400.

Enlace del vídeo: *pendiente de insertar*

8.1 Guion

Escena	Duración	Qué se muestra
1. Presentación	0:00–0:30	Tema, objetivo y por qué los firewalls son blanco de ataques
2. Qué es un NGFW	0:30–1:15	Diferencia entre firewall tradicional y NGFW; App-ID, User-ID y Content-ID
3. Recorrido de la consola	1:15–2:15	Dashboard, Monitor > Logs de tráfico y de amenazas en PAN-OS o Strata Cloud Manager
4. Perfil de protección	2:15–3:15	Crear un perfil de Vulnerability Protection y aplicarlo a una regla de seguridad
5. Revisar parches	3:15–4:00	Device > Software: ver la versión de PAN-OS y comparar con el aviso de seguridad
6. Endurecer la gestión	4:00–4:40	Restringir la interfaz de administración a IPs permitidas y activar MFA
7. Cierre	4:40–5:00	Tres recomendaciones clave y conclusión

8.2 Recursos gratuitos para grabarlo

- Documentación oficial de PAN-OS: Getting Started, con versión en español.
- Cursos gratuitos de Palo Alto Networks Beacon y prueba de Strata Cloud Manager Essentials.
- Aviso público del caso en security.paloaltonetworks.com para mostrar en la escena 5.

9. Conclusiones

1. Palo Alto Networks pasó de un firewall a una plataforma: su arquitectura SP3 le permitió prevenir en línea sin sacrificar rendimiento, y eso definió el firewall moderno.
2. Hoy compite por consolidar red, nube, SOC, identidad e IA bajo una misma inteligencia compartida, lo que reduce herramientas pero aumenta la dependencia del fabricante.
3. El caso CVE-2024-3400 demuestra que ninguna herramienta es invulnerable: el equipo que protege la red puede convertirse en la puerta de entrada si no se parchea a tiempo.
4. Las consecuencias de una vulnerabilidad explotada van más allá de lo técnico: afectan datos, dinero, cumplimiento legal y reputación.
5. Su precio la orienta a medianas y grandes empresas; para estudiantes y pymes existen niveles gratuitos, pruebas y formación.

10. Recomendaciones

- **Para las organizaciones:** aplicar parches en cuanto se publiquen y suscribirse a los avisos de seguridad del fabricante.
- **Para los administradores:** nunca exponer la interfaz de gestión a internet y usar autenticación multifactor en todas las cuentas de administración.
- **Para la defensa en profundidad:** no confiar en una sola capa; combinar firewall, protección de endpoints, gestión de identidades y monitoreo.
- **Para los equipos de TI:** revisar periódicamente qué servicios están expuestos con herramientas como Cortex Xpanse o un escaneo propio.
- **Para las pymes:** evaluar el costo total (hardware + suscripciones + personal) antes de comprar, y comparar con alternativas.
- **Para los estudiantes:** aprovechar los cursos gratuitos de Beacon y la certificación PCNSA como entrada a la ciberseguridad de redes.

11. Infografía

Resumen visual del proyecto: qué es Palo Alto Networks, cómo previene, el caso CVE-2024-3400 y las tres recomendaciones clave.



Figura 4 · Infografía del proyecto (elaboración propia)

Fuentes

- Palo Alto Networks — resultados del año fiscal 2026, cierre de la adquisición de CyberArk (feb. 2026), presentación de Cortex Cloud (feb. 2025) y whitepaper *Single Pass Parallel Processing Architecture*.
- Palo Alto Networks TechDocs — PAN-OS Getting Started
- H-ISAC / AHA — Threat Update CVE-2024-3400
- The Register — Zero-day exploited in GlobalProtect gateways
- Arctic Wolf — CVE-2024-3400
- PolySwarm — Operation MidnightEclipse
- Cybersecurity News — PAN-OS Zero-day Under Active Attack
- Precios referenciales 2026: Redress Compliance, AIMultiple, CostBench, OptiNOC.
- Ilustraciones y diagramas: elaboración propia, libres de derechos de autor.